

Enterprise DevSecOps MNC Readiness Audit

Owner: Rimanshu Sharma | Audit date: 2026-06-18

Scope: GitHub portfolio readiness, application security, DevSecOps automation, Kubernetes hardening, supply-chain evidence, runtime detection, compliance reporting, and recruiter presentation quality.

Executive Verdict

The project is technically strong and broad. It already demonstrates AppSec, CI/CD gates, Kubernetes security, GitOps, SBOM, signing/provenance, runtime detection, evidence screenshots, and PTaaS-style reporting. Before public submission, the highest-risk issue is credibility: several existing PDF reports contain an old author name and should be regenerated or removed from the public repository.

Category	Score	Reviewer note
AppSec depth	8/10	SQLi, command injection, unsafe rendering, findings, tests
DevSecOps automation	8/10	Bandit, pip-audit, Trivy, SARIF, security gates
Kubernetes security	8/10	Non-root, RBAC, NetworkPolicy, Pod Security, kube-bench evidence
Supply chain	7.5/10	SBOM/Cosign/provenance present; strengthen verification enforcement
Evidence quality	7/10	Strong screenshot/report volume; needs hash manifest and author cleanup
Presentation	6.5/10	README is detailed but should be sharper and source docs should back PDFs

Critical Findings

Priority	Finding	Action
P0	Old author name appears in existing PDF reports.	Regenerate PDFs from Markdown sources or remove old PDFs before public GitHub submission.
P0	Original tests failed due to missing security headers.	Patched app.py with baseline security headers; pytest now passes: 42 passed, 1 xfailed.
P1	Vulnerable and secure modes needed clearer separation.	Added app_hardened.py, requirements-secure.txt, and hardened regression tests.
P1	Evidence lacked integrity manifest.	Generated docs/professional/evidence_manifest.csv with SHA256 hashes.
P2	Repo governance templates were missing.	Added CODEOWNERS, Dependabot, PR template, security finding template, exception template.

Files Added in Upgrade Pack

Area	Files
Professional docs	MNC audit/action plan, compliance crosswalk, control matrix, evidence standard, risk register, retest template, API test plan, Kubernetes backlog, supply-chain backlog, interview bullets, presentation checklist.
Code remediation	src/app/app_hardened.py, src/app/requirements-secure.txt, tests/test_hardened_app.py.
Repo governance	.github/CODEOWNERS, dependabot.yml, PR template, security finding issue template, enterprise release evidence workflow.
Evidence integrity	scripts/generate_evidence_manifest.py and docs/professional/evidence_manifest.csv.
Quality checks	scripts/validate_professional_readiness.py and scripts/name_audit.py.

Recommended Public GitHub Rule

Keep the main README sharp and recruiter-friendly. Move long explanations into docs/professional. Public claims should always link to source code, scan output, screenshots, or a row in the control validation matrix. Do not publish PDF reports until the author-name audit is clean.

Final Interview Story

I built a private enterprise DevSecOps lab that follows a consulting lifecycle: build, break, detect, harden, retest, and report. It demonstrates vulnerable code, CI/CD security gates, container and Kubernetes hardening, GitOps governance, SBOM/signing/provenance evidence, runtime detection, and professional PTaaS-style reporting. I also mapped controls to NIST SSDF, OWASP ASVS, CIS Kubernetes, SLSA, and SOC 2/ISO-style control families for portfolio purposes.

Limitation

This audit did not safely rewrite all existing PDFs because binary PDF text replacement can damage layout and leave hidden metadata behind. The safer enterprise-grade approach is to regenerate PDFs from source Markdown using the correct owner name and then rerun scripts/name_audit.py.